

CE QUE CE GUIDE FIABILISE

Les **7 questions sur la Row-Level Security** qui séparent un candidat qui a lu la doc d'un candidat qui a sécurisé un modèle en production.

Le RLS, presque tout le monde sait le citer ; presque personne ne sait l'expliquer juste. La définition exacte, le mécanisme table de sécurité plus relation plus filtre DAX, le statique contre le dynamique, et le piège import contre DirectQuery : c'est là que se joue l'entretien.

01 LE CONCEPT · CE QUE LE RLS FAIT VRAIMENT

questions 1 à 3 ● ● ●

1. Qu'est-ce que le RLS fait exactement, et que ne fait-il pas ?



LE PIÈGE Décrire le RLS comme un masquage de visuels ou de pages selon le profil. C'est faux, et un bon recruteur le repère en une phrase.

RÉPONSE Le RLS (Row-Level Security) filtre la **donnée**, pas l'affichage. Il restreint les *lignes* du modèle qu'un utilisateur peut voir : un commercial Nord ne voit que les lignes Nord, dans tous les visuels, tous les rapports, toutes les exports. Il n'enlève pas un graphique, ne cache pas une page, ne grise pas un bouton. Tout le monde voit les mêmes visuels, mais alimentés par des données filtrées.

Conséquence directe : pour cacher une page ou un visuel à un profil, le RLS n'est pas l'outil. C'est de la sécurité d'objet (object-level security) ou de la conception de rapport, deux sujets distincts.

2. Quelle est la différence entre un rôle RLS et une permission de rapport ?

LE PIÈGE Confondre « donner accès au rapport » et « appliquer le RLS ». Ce sont deux couches qui s'empilent, pas la même.

EN PRATIQUE La permission de rapport (accès à l'espace de travail ou à l'application, partage) décide *si* l'utilisateur ouvre le rapport. Le rôle RLS décide *quelles lignes* il voit une fois entré. Un utilisateur peut avoir l'accès au rapport sans être mappé à un rôle : selon la configuration, il verra alors un rapport vide ou complet. Donner l'accès ne suffit jamais à sécuriser : il faut **assigner les membres aux rôles** côté service.

Point d'attention senior : un utilisateur avec un droit d'administration (Admin, Member, Contributor) sur l'espace de travail **contourne le RLS**. Le RLS ne s'applique qu'aux Viewers et aux destinataires d'application.

3. Techniquement, comment le RLS est-il construit dans un modèle ?

RÉPONSE Trois ingrédients, dans cet ordre :

- une **table de sécurité** qui associe chaque utilisateur à son périmètre (région, entité, magasin) ;
- une **relation** entre cette table et les dimensions du modèle, pour propager le filtre ;
- un **filtre DAX** posé sur le rôle, écrit comme une expression booléenne sur une table.

Le filtre DAX renvoie vrai ou faux ligne à ligne. Exemple sur une dimension région :

```
[Region] = "Nord"
```

Power BI applique ce filtre à la table ciblée, puis la relation propage la restriction au reste du modèle. C'est ce filtre, et lui seul, qui fait le travail.

4. Comment tester un rôle sans se connecter avec dix comptes différents ?

RÉPONSE Avec le « Voir en tant que » (View as roles) de Power BI Desktop : tu simules un rôle, et pour le RLS dynamique tu simules *en plus* un utilisateur donné. Le rapport se recharge comme si cette personne le consultait, ce qui te montre exactement les lignes visibles.

LE PIÈGE Croire que le test en Desktop garantit le résultat en ligne. Il valide la **logique du filtre**, pas le **mapping des membres**, qui se fait dans le service Power BI sur le modèle publié. Un rôle parfait dont personne n'est membre ne sécurise rien.

Réflexe d'entretien : citer les deux niveaux de test, Desktop pour la logique, service pour l'assignation, montre que tu as déployé, pas seulement lu.

5. RLS statique ou dynamique : quelle différence, et quand l'un ou l'autre ? ★

RÉPONSE Le RLS **statique** code la valeur en dur dans le rôle (un rôle « Nord » avec [Region] = "Nord"). Simple, mais il faut un rôle par périmètre et l'assignation manuelle : ingérable au-delà de quelques zones.

Le RLS **dynamique** n'a qu'un seul rôle. Il identifie l'utilisateur connecté avec USERPRINCIPALNAME () (l'adresse de connexion), puis le rapproche de la table de sécurité :

```
[Email] = USERPRINCIPALNAME ( )
```

Un seul rôle couvre alors mille utilisateurs : on ajoute une ligne dans la table de sécurité, pas un rôle. C'est la réponse attendue dès qu'on parle d'échelle.

LE PIÈGE Utiliser USERNAME () sans savoir qu'il se comporte différemment selon le contexte. Dans le service Power BI, USERPRINCIPALNAME () est la valeur fiable à comparer aux e-mails de la table de sécurité.

03 LE TERRAIN · PIÈGES DE PRODUCTION ET LECTURE DU RECRUTEUR

6. Le RLS se comporte-t-il pareil en mode Import et en DirectQuery ? ★

LE PIÈGE Croire qu'en mode Import le RLS empêche le chargement des données sensibles. C'est l'erreur la plus révélatrice en entretien.

EN PRATIQUE En mode **Import**, toutes les lignes sont chargées dans le moteur VertiPaq au rafraîchissement, RLS ou pas. Le RLS s'applique *à la requête* : à chaque interrogation du modèle, le moteur n'expose que les lignes autorisées par le rôle. Il filtre la lecture, il n'empêche pas le chargement. Conséquence : la donnée complète vit dans le fichier ; quiconque accède au fichier source ou contourne le RLS y accède.

En **DirectQuery**, le filtre RLS est traduit dans la requête envoyée à la source : la base de données ne renvoie que les lignes autorisées. Le périmètre n'a jamais transité par le modèle. Pour une vraie isolation physique de données très sensibles, c'est l'argument en faveur du DirectQuery, ou d'un cloisonnement à la source.

7. Au fond, qu'est-ce qu'un recruteur teste vraiment avec le RLS ?

RÉPONSE Pas la syntaxe : le bon sens sécurité. Trois signaux qu'il cherche derrière la question :

- tu distingues **filtrer la donnée** de **cacher un visuel** (question 1) ;
- tu sais que le RLS **ne suffit pas seul** : assignation des membres, contournement par les admins, droits d'espace de travail (questions 2 et 4) ;
- tu connais ses **limites physiques** : en import la donnée reste chargée, le RLS filtre la requête (question 6).

Un candidat qui récite la définition passe ; un candidat qui nomme un piège réel (l'admin qui contourne, la donnée import toujours présente, le rôle sans membre) marque. La sécurité, ça se prouve par les angles morts qu'on a vus.

LE RÉFLEXE À RETENIR

1. **Le RLS filtre la donnée à la requête, il ne masque pas le visuel et n'empêche pas le chargement.** Tout le reste (statique vs dynamique, import vs DirectQuery, voir en tant que) découle de cette seule phrase.

→ Garde ces 7 réponses sous la main : ce sont elles qui te départagent quand le reste de l'entretien est à égalité.